

PENETRATION TESTING FUNDAMENTALS

MODULE 3

Reconnaissance

Student Study Guide

Topics: Active & Passive Reconnaissance · DNS · OSINT · Nmap · Enumeration · Vulnerability Scanning · Analysis

1. What Is Reconnaissance?

Reconnaissance is always the initial step in a cyber attack. An attacker must first gather information about the target in order to be successful. The term reconnaissance comes from the military world, where it describes gathering information about the enemy — such as the enemy's location, capabilities, and movements — before launching an attack. In penetration testing, reconnaissance typically consists of scanning and enumeration.

KEY CONCEPT

Reconnaissance sets the entire direction of an engagement. The more information gathered here, the more targeted and effective later phases become.

1.1 Active Reconnaissance

Active reconnaissance is a method of information gathering in which tools send out probes to the target network or system to elicit responses. These responses are then used to determine the posture of the network or system. Active reconnaissance directly interacts with the target and sends traffic to it, making it more likely to be detected by firewalls or intrusion detection systems (IDS).

IMPORTANT

Be careful with active scanning near fragile devices such as printers or IoT equipment. Sending probes to devices with weak TCP/IP stacks can crash them. Always adjust your scanner settings based on the target.

Common Active Reconnaissance Methods

- Host enumeration
- Network enumeration
- User enumeration
- Group enumeration
- Network share enumeration
- Web page / web application enumeration
- Application enumeration
- Service enumeration
- Packet crafting

 NOTE

In ethical hacking, enumeration is the process of actively gathering detailed information about a target's systems, services, and user accounts — performed after the initial reconnaissance phase.

1.2 Passive Reconnaissance

Passive reconnaissance is a method of information gathering in which the tools do not interact directly with the target device or network. Some passive methods use third-party databases; others listen to traffic on the network and deduce information from the communication patterns. Passive recon is much less invasive, unlikely to crash systems, and unlikely to be detected.

 TIP

Passive recon is ideal when testing a production network that cannot be disrupted. It leaves no footprint on the target.

Common Passive Reconnaissance Methods

- Domain enumeration
- Packet inspection
- Open-source intelligence (OSINT)
- Recon-ng
- Eavesdropping

2. DNS Lookups

Attackers typically start with a small amount of information and gather more while scanning. A common starting point is DNS lookups — resolving the target domain to IP addresses, including subdomains such as `www`, `mail`, and `portal`. Tools include `dnsrecon`, `nslookup`, `host`, and `dig`.

Example: dnsrecon Output for h4cker.org

```
$ dnsrecon -d h4cker.org
[*] DNSSEC is configured for h4cker.org
```

```
[*] SOA ns-cloud-c1.googledomains.com 216.239.32.108
[*] NS ns-cloud-c1.googledomains.com 216.239.32.108
[*] NS ns-cloud-c2.googledomains.com 216.239.34.108
www.h4cker.org --> 185.199.108.153
mail.h4cker.org --> 185.199.110.153
portal.h4cker.org --> 185.199.110.153
```

Once DNS lookups reveal which hosts exist, the attacker uses a tool like Nmap to identify what services are running on those hosts.

3. Identifying Technical & Administrative Contacts (Whois)

The Whois tool reveals domain registration details including registrar, creation/expiry dates, name servers, and contact information. Many organisations use privacy services to hide registrant details — but abuse contact information and name servers are still exposed.

Example: whois h4cker.org

```
$ whois h4cker.org
Domain Name: H4CKER.ORG
Registrar: Google LLC
Creation Date: 2018-05-04
Registry Expiry Date: 2028-05-04
Registrar Abuse Contact Email: registrar-abuse@google.com
Registrant Organization: Contact Privacy Inc.
DNSSEC: signedDelegation
Name Server: NS-CLOUD-C1.GOOGLEDOMAINS.COM
```

TIP

Tools like Recon-ng, theHarvester, and Maltego automate passive recon and support many DNS-based and Whois queries. See: github.com/The-Art-of-Hacking/h4cker/tree/master/osint

4. Cloud vs. Self-Hosted Applications

A company can own a domain but have its applications hosted entirely in the cloud. For example, netflix.com resolves to IP addresses that are actually owned by Amazon Web Services (AWS) — not Netflix itself. Running whois on the IP addresses (rather than the domain) reveals the true hosting provider.

Example: Discovering Cloud Hosting

```
$ host netflix.com
netflix.com has address 3.230.129.93
netflix.com has address 52.3.144.142
netflix.com has address 54.237.226.164

$ whois 3.230.129.93 | grep OrgName
OrgName: Amazon Technologies Inc.
```

KEY CONCEPT

Always check the ownership of the IP addresses — not just the domain. A company may own the domain but not the infrastructure it runs on.

5. Social Media Scraping & Job Listings

5.1 Social Media

Attackers scrape social media platforms (LinkedIn, Twitter, Facebook, Instagram) to gather information about employees: their hobbies, travel patterns, work promotions, business contacts, and more. This information fuels social engineering attacks such as spear phishing and whaling.

5.2 Job Listings

Job postings on sites like Indeed, LinkedIn, and CareerBuilder often reveal an organisation's technology stack — without the attacker having to run any tools. For example, a posting for a 'Cisco firewall administrator, Ansible expert, and MongoDB architect in Raleigh' tells an attacker exactly what the company is running.

IMPORTANT

Attackers have even created fake job postings to interview victims — getting them to reveal details about their employer's technology, architecture, and applications during interviews.

6. Cryptographic Flaws & Certificate Transparency

During reconnaissance, attackers can inspect SSL/TLS certificates to gather valuable information about an organisation. A certificate contains: the serial number, subject common name, URI, organisation name, OCSP information, and the CRL URI.

 NOTE

Certificate revocation: If an application is decommissioned or its certificate is compromised, the certificate should be revoked and added to a Certificate Revocation List (CRL). OCSP and CRLs allow parties to verify whether a certificate is still valid.

6.1 Certificate Transparency

Certificate transparency was created after a major attack against DigiNotar raised concerns about malicious certificate issuance. It allows any organisation or individual to transparently verify that a digital certificate was genuinely issued — and lets attackers enumerate subdomains by reviewing what certificates have been issued for a domain.

 TIP

Learn more at: certificate.transparency.dev

7. Company Reputation & Security Posture

Security breaches directly affect company reputation. Attackers use data from past breaches to build a fuller picture of a target. Common sources include:

7.1 Password Dumps

Breach data is available via Pastebin, the dark web, and even GitHub. Tools that help search for exposed credentials:

- **h8mail:** Find emails and passwords exposed in previous breaches (pip3 install h8mail)
- **WhatBreach:** github.com/Ekultek/WhatBreach
- **LeakLooker:** github.com/woj-ciech/LeakLooker
- **Buster:** github.com/sham00n/buster

- **PwnDB:** github.com/davidtavarez/pwndb

NOTE

These tools leverage repositories like haveibeenpwned.com and snusbase.com to find leaked credential data.

7.2 File Metadata

Metadata embedded in images, Word documents, Excel files, and PDFs can reveal device information, GPS location, author name, software version, and more. Exif (Exchangeable Image File Format) data from a single iPhone photo can include: GPS coordinates, device model, aperture, shutter speed, and timestamp.

TIP

ExifTool is one of the most popular tools for reading metadata from image and document files.

7.3 Strategic Search Engine Analysis (Google Dorking)

Search engines can be powerful vulnerability discovery tools when combined with advanced operators. These searches are called Google dorks.

Common Google Advanced Operators

Operator	What It Does	Example
filetype:	Search within a specific file type	filetype:xls
inurl:	Search within URLs	inurl:admin
link:	Search within hyperlinks	link:www.target.com
intitle:	Search within document titles	intitle:"Index of /etc"

Example Google Dorks

```
# Find session IDs in publicly accessible logs:
intext:JSESSIONID OR intext:PHPSESSID inurl:access.log ext:log

# Find exposed credentials in public files:
"public $user =" | "public $password =" | "public $secret =" ext:txt | ext:log -
git
```

 NOTE

The Google Hacking Database (GHDB) at exploit-db.com/google-hacking-database is a community resource cataloguing hundreds of Google dorks across categories: footholds, sensitive directories, vulnerable files, login portals, and more.

7.4 Website Archiving / Caching

The Wayback Machine (archive.org/web) archives and caches websites over time. An attacker can view old versions of a site to find content or technology details that were later removed.

7.5 Public Source Code Repositories

GitHub and GitLab can expose application architecture, vulnerable dependencies, configuration files, and even hardcoded credentials. Even when no direct vulnerability is found, public repositories reveal insights into an organisation's infrastructure and development practices.

8. Open-Source Intelligence (OSINT) Gathering

Open-source intelligence (OSINT) gathering is the collection and analysis of publicly available information about a target. The information is 'open source' because it requires no covert methods — it can typically be found on the Internet. The larger an organisation's online presence, the more OSINT is available.

 KEY CONCEPT

OSINT can often start with a simple Google search and expand from there into DNS, Whois, social media, certificate transparency, GitHub, and more.

8.1 Recon-ng

Recon-ng is a modular framework developed in Python with Metasploit's msfconsole interface in mind. It is especially effective for social networking site enumeration and includes built-in reporting for deliverables.

Recon-ng Workflow

1. **Start:** Run recon-ng from a terminal
2. **View commands:** Type help and press Enter
3. **Search the marketplace:** Use marketplace search to find available modules
4. **Understand module indicators:** D = has dependencies; K = requires an API key
5. **Refresh the marketplace:** Use marketplace refresh to get latest modules
6. **Search for a specific module:** marketplace search <keyword> e.g. marketplace search bing
7. **Install a module:** marketplace install recon/domains-hosts/bing_domain_web
8. **Show installed modules:** modules search
9. **Load a module:** modules load recon/domains-hosts/bing_domain_web
10. **Set the target domain:** options set SOURCE h4cker.org
11. **Run:** Type run to execute

8.2 Shodan

Shodan continuously scans the entire Internet 24 hours a day, 365 days a year. The results are stored in a searchable database at shodan.io (or via API). Shodan can find vulnerable hosts, IoT devices, industrial control systems, and other systems that are unexpectedly exposed to the public Internet.

IMPORTANT

Even though Shodan shows public information, never interact with systems you find there without the owner's explicit permission. If the system has a bug bounty programme, responsible disclosure may earn you a reward.

9. Active Reconnaissance: Port Scanning

A port scan is an active scan in which the tool sends probes to target IP addresses and examines the responses to determine whether services are listening. Nmap is the most widely used tool for port scanning.

9.1 Nmap SYN Scan (Half-Open Scanning)

Nmap's SYN scan sends a TCP SYN packet to each port being probed. It is called 'half-open' because the full TCP three-way handshake is never completed. The table below shows how to interpret responses:

Nmap Result	Response from Target	Meaning
Open	TCP SYN-ACK	The service is actively listening on the port
Closed	TCP RST	The service is not listening on the port
Filtered	No response or ICMP unreachable	The port is firewalled — state cannot be determined

10. Nmap Scan Types

10.1 TCP Connect Scan (-sT)

Uses the underlying OS networking mechanism to establish a full TCP three-way handshake. This is the default scan type when raw packet privileges are not available. It creates more traffic, is more likely to be logged, and more likely to trigger IDS alarms than a half-open scan.

NOTE

Nmap scans only the 1,000 most common ports by default. Use the `-p` option to specify additional ports. Nmap Cheat Sheet: github.com/The-Art-of-Hacking/h4cker/blob/master/cheat_sheets/NMAP_cheat_sheet.md

10.2 UDP Scan (-sU)

Used to scan for UDP-based services such as DNS (port 53), SNMP (port 161), and DHCP (port 67/68). Nmap sends a UDP packet to each port. If it receives an ICMP port unreachable reply, the port is marked closed. If no response is received, the port is marked open|filtered.

NOTE

UDP port scans can take much longer than TCP scans because ICMP unreachable messages are rate-limited on many systems. ICMP rate limiting is primarily used to throttle worm-like behaviour.

10.3 TCP FIN Scan (-sF)

A FIN packet is sent to each port. If the port is closed, the target responds with an RST packet. If nothing is received, the port is considered open (because normal behaviour for an open port is to ignore the FIN).

IMPORTANT

TCP FIN scans are not useful against Windows systems. Windows responds with RST packets regardless of port state, making it impossible to differentiate open from closed ports.

10.4 Host Discovery Scan (-sn)

Used to identify which hosts are online on a network without performing a full port scan. By default, -sn sends: an ICMP echo request, a TCP SYN to port 443, a TCP ACK to port 80, and an ICMP timestamp request. If the target responds to any of these, it is considered alive.

10.5 Timing Options (-T 0–5)

Nmap provides six timing templates to control scan aggressiveness:

Option	Name	Description
-T0	Paranoid	Very slow — designed for IDS evasion. Sends one probe at a time.
-T1	Sneaky	Slow — also for IDS evasion but slightly faster than T0.
-T2	Polite	Slows down to consume less bandwidth — ~10x slower than default.
-T3	Normal	Default — dynamic timing based on target responsiveness.
-T4	Aggressive	Assumes a fast, reliable network — may overwhelm weaker targets.
-T5	Insane	Very aggressive — likely to overwhelm targets or miss open ports.

11. Types of Enumeration

Enumeration is one of the core activities in the information-gathering phase of a penetration test. This section covers the most important enumeration techniques and the tools used to perform them.

11.1 Host Enumeration

Host enumeration identifies which hosts are alive on a target network. When performed externally, limit scans to the in-scope IP ranges. When performed internally, scan the full subnet. Common tools: Nmap, Masscan, and vulnerability scanners.

11.2 User Enumeration

Gathering a valid list of usernames is the first step toward cracking credentials. On Windows networks, this is done by manipulating the SMB protocol on TCP port 445. Two key SMB messages reveal user information:

- **SMB_COM_NEGOTIATE:** The client and server agree on protocols, flags, and options. The server response can reveal signature requirements, authentication mechanisms (share vs user level), whether plaintext passwords are allowed, and server time/timezone.
- **SMB_COM_SESSION_SETUP_ANDX:** Handles authentication. The message includes username, password, and domain. If unencrypted, credentials can be sniffed directly from the network. Even encrypted credentials can sometimes be cracked using tools that target Lanman and NTLM.

11.3 Group Enumeration

Group enumeration helps determine the authorization roles used in the target environment. The Nmap NSE script `smb-enum-groups` pulls the list of groups and their members from a remote Windows machine.

```
nmap --script smb-enum-groups.nse -p445 <host>
```

11.4 Network Share Enumeration

Identifying shared files, folders, and printers builds out the internal attack surface. The `smb-enum-shares` NSE script uses Microsoft Remote Procedure Call (MSRPC) to enumerate network shares.

```
nmap --script smb-enum-shares.nse -p445 <host>
```

 NOTE

Additional tools for SMB enumeration include enum4linux, enum4linux-ng (Python), and smbclient. The -sC option in Nmap runs the most common NSE scripts automatically based on open ports found.

11.5 Web Page / Web Application Enumeration

Once a web server is identified, map out its attack surface. The Nmap http-enum NSE script brute-forces common directory and file paths to identify things like default admin pages (Apache Tomcat manager, etc.).

```
nmap -sV --script=http-enum <target>
```

Nikto is another web server enumeration tool — an open-source vulnerability scanner that quickly identifies web server configurations, default files, and potentially vulnerable components. It is fast but noisy.

11.6 Service Enumeration

Service enumeration identifies the exact services and versions running on open ports. Nmap's smb-enum-processes NSE script enumerates running services on a Windows system using provided credentials.

```
nmap --script smb-enum-processes.nse --script-args  
smbusername=<user>,smbpass=<pass> -p445 <host>
```

11.7 Packet Crafting with Scapy

Scapy is a comprehensive Python-based framework for packet generation and analysis — one of pentesters' favourite tools for custom network reconnaissance.

- Must be run with root/sudo permissions to modify and send packets
- Launch: `sudo scapy`

- Use `ls()` to list all supported protocols and packet formats
- Can be scripted to build custom scanners for any protocol

**TIP**

Scapy examples and Python scanning scripts: github.com/The-Art-of-Hacking/h4cker/blob/master/python_ruby_and_bash

12. How Vulnerability Scanners Work

Vulnerability scanners automate the process of finding known weaknesses in systems. They all differ in detail, but most follow the same four-step process:

- 12. Discovery:** The scanner uses Nmap (or similar) to enumerate hosts and open ports. It then probes open ports for more information.
- 13. Fingerprinting:** When enough information is available to identify the software and version running on a port, that information is recorded in a database.
- 14. Correlation:** The scanner cross-references its findings against a database of known vulnerabilities (CVEs) to identify potential matches.
- 15. Reporting:** The scanner produces a report of suspected vulnerabilities. Note: many results are false positives and must be manually validated.

13. Types of Vulnerability Scans

13.1 Unauthenticated Scans

Scans the target without credentials — from the perspective of an unauthenticated remote attacker. Only shows network services that are exposed. Faster to set up but produces more false positives.

13.2 Authenticated Scans

Provides the scanner with root-level credentials. The scanner logs in via SSH (or similar) and runs commands like netstat to gather information from inside the host. Results are far more accurate.

Netstat: Non-root vs Root Access

```
# Without root - PID/Program name is hidden:
$ netstat -tunap
tcp  0  0  0.0.0.0:80      0.0.0.0:*    LISTEN  -

# With root - full process details visible:
$ sudo netstat -tunap
tcp  0  0  0.0.0.0:80      0.0.0.0:*    LISTEN  506/docker-proxy
tcp  0  0  0.0.0.0:22      0.0.0.0:*    LISTEN  161/sshd
```

NOTE

Authenticated scans provide a significantly lower rate of false positives than unauthenticated scans.

13.3 Discovery Scans

Identifies the attack surface — open ports and the services running on them. The scanner probes each open port to fingerprint the exact service (e.g. Apache Tomcat 8.5.22 on port 80, OpenSSH on port 22). Results feed into further targeted scanning.

13.4 Full Scans

Enables every scanning option and plugin category in the scan policy. Nessus, for example, has over 80 plugin categories including AIX, Windows, CGI, DNS, Databases, Firewalls, and more. Not all plugins apply to every device — customise the selection to the target environment to reduce noise and speed up scanning.

13.5 Stealth Scans

A stealth scan is designed to scan a production environment without triggering defensive alerts. Techniques include: using SYN scans (half-open) instead of full TCP connects, disabling noisy plugins (especially DoS-style checks), and using a passive vulnerability scanner that only monitors network traffic rather than sending probes.

13.6 Compliance Scans

Compliance scans check whether systems meet specific regulatory or organizational standards — such as PCI-DSS, HIPAA, ISO 27001, or internal security policies. Vulnerability scanners can import compliance policy files that map requirements to specific scanner plugins. Custom compliance policies can be created for fine-tuned engagements.

NOTE

Compliance requirements vary by industry and can be interpreted in different ways. Some checks are straightforward (expecting a specific command output) while others require human judgement.

14. Challenges When Running a Vulnerability Scan

Challenge	What to Consider
Best time to scan	Avoid peak hours on production networks. Scan during early morning when utilisation is lowest. Vulnerability scanning creates significant network noise.
Protocols in use	Scan both TCP and UDP. Scanning only TCP means missing vulnerabilities in DNS, SNMP, and DHCP services running on UDP.
Network topology	Always scan as close to the target as possible. Avoid crossing WAN links — they impact bandwidth and other devices. A firewall or network device between scanner and target may skew results.
Bandwidth limitations	Adjust scanner settings when working over VPN or WAN links. DoS-style plugins are especially bandwidth-heavy and should be throttled or disabled.
Query throttling	Reduce the number of concurrent attack threads, or narrow the scope of plugins. This reduces the risk of crashing the target and improves scan reliability.
Fragile systems / IoT	Printers and IoT devices may crash under standard scan loads. Either throttle the scan dramatically or exempt them — though exempting reduces overall security coverage.

15. Analysing Vulnerability Scan Results & Eliminating False Positives

Running the scan is the easy part. The majority of the work is analysing and validating results. False positives waste time, damage credibility with clients and internal teams, and must be systematically eliminated.

Steps to Validate a Finding

- 16. Check how the finding was discovered:** Was it a credentialed scan (log-in-based) or a remote banner grab? Credentialed findings are far more reliable.
- 17. Connect directly to the target:** Manually verify the version information of the service in question.
- 18. Read the CVE details:** Each vulnerability maps to one or more CVE entries. Check the exact criteria — a vulnerability may only be exploitable on a specific OS version or distribution.
- 19. Check for backporting:** Some Linux distributions (e.g. Red Hat) report older version strings for services that have already been patched. Don't assume an old version number = vulnerable.
- 20. Attempt exploitation:** The ultimate validation of a vulnerability is successful exploitation.

KEY CONCEPT

Backporting: taking a security patch from a newer software version and applying it to an older version — without changing the version number. Like installing a modern safety feature in an older car model.

16. Sources for Vulnerability Research

Source	Purpose	URL
CVE	Catalog of publicly known vulnerabilities. IDs formatted as CVE-YYYY-NNNNN.	cve.mitre.org
CWE	Common language for software weakness root causes.	cwe.mitre.org

CVSS	Industry-standard severity scoring (0–10 scale): base, temporal, and environmental scores.	first.org/cvss
CAPEC	Community catalog of real-world attack patterns, maintained by MITRE.	capec.mitre.org
US-CERT	U.S. government vulnerability data sharing and cybersecurity guidance.	us-cert.gov
CERT/CC	Carnegie Mellon vulnerability coordination, research, and training.	cert.org
JPCERT	Japan/Asia Pacific incident response and CSIRT activities.	jpcert.or.jp
NIST / NVD	NIST Cybersecurity Framework and National Vulnerability Database.	nist.gov/cyberframework

 NOTE

CVSS scores: 0 = informational, 4–6 = medium severity, 7–8.9 = high, 9–10 = critical. A score of 10 typically indicates a remotely exploitable, unauthenticated vulnerability with full system takeover.

17. How to Deal with a Vulnerability

After identifying a vulnerability, you must verify it. Check Metasploit first — if a vulnerability has a matching Metasploit module, it should almost always be treated as high severity. Then prioritise using the questions below:

Prioritisation Questions

- What is the severity of the vulnerability? (Use CVSS)
- How many systems are affected?
- How was the vulnerability detected — automated scanner or manual discovery?
- What is the value of the affected device? Is it critical to the business?
- What is the attack vector, and does it apply to this environment?
- Is a workaround or mitigation available?

Recommended Priority Order

21. **Highest severity vulnerabilities:** especially those that could already be actively exploited. If a system appears to be actively compromised, report it immediately.
22. **Vulnerabilities on critical systems:** regardless of severity. Exploit chains can elevate a low-severity finding to critical.
23. **Findings affecting many systems:** a vulnerability across 100 systems has far greater potential impact than one affecting a single device.

IMPORTANT

If at any time during a penetration test you find evidence that a system is being actively exploited by a real attacker, stop and report it immediately to the system owner.

18. Module Summary & Key Takeaways

REMEMBER

Reconnaissance is the foundation of every successful penetration test. The quality of information gathered here determines the effectiveness of every phase that follows.

Key Takeaways

24. Reconnaissance always comes first — map the terrain before you attack.
25. Active recon sends traffic to the target and may be detected. Passive recon observes without interaction.
26. DNS, Whois, certificates, social media, job listings, and GitHub all leak valuable intelligence — without any exploitation.
27. Nmap is the core active recon tool — master its scan types (-sT, -sU, -sF, -sn) and timing options (-T0 to -T5).
28. Enumeration types — host, user, group, share, web, service — build a detailed picture of the attack surface.
29. Vulnerability scanners automate discovery but require human analysis to eliminate false positives.
30. Always validate scanner findings manually — check CVE criteria, version numbers, and backporting before reporting.
31. Prioritise vulnerabilities by severity, system criticality, and number of affected systems.

Quick Reference: Passive vs Active Recon

	Passive Reconnaissance	Active Reconnaissance
Interaction with target	None — uses third-party sources	Direct — sends packets/probes to target
Detectability	Very low — no footprint on target	Higher — traffic visible to IDS/firewalls
Risk of disruption	None	Can crash fragile systems (printers, IoT)
Examples	DNS, Whois, OSINT, social media, certs	Nmap, Nikto, enumeration scripts, Scapy
Best for	Production environments that can't be disrupted	Complete attack surface mapping

End of Module 3